



LoanTrack

Two-Domain Architecture

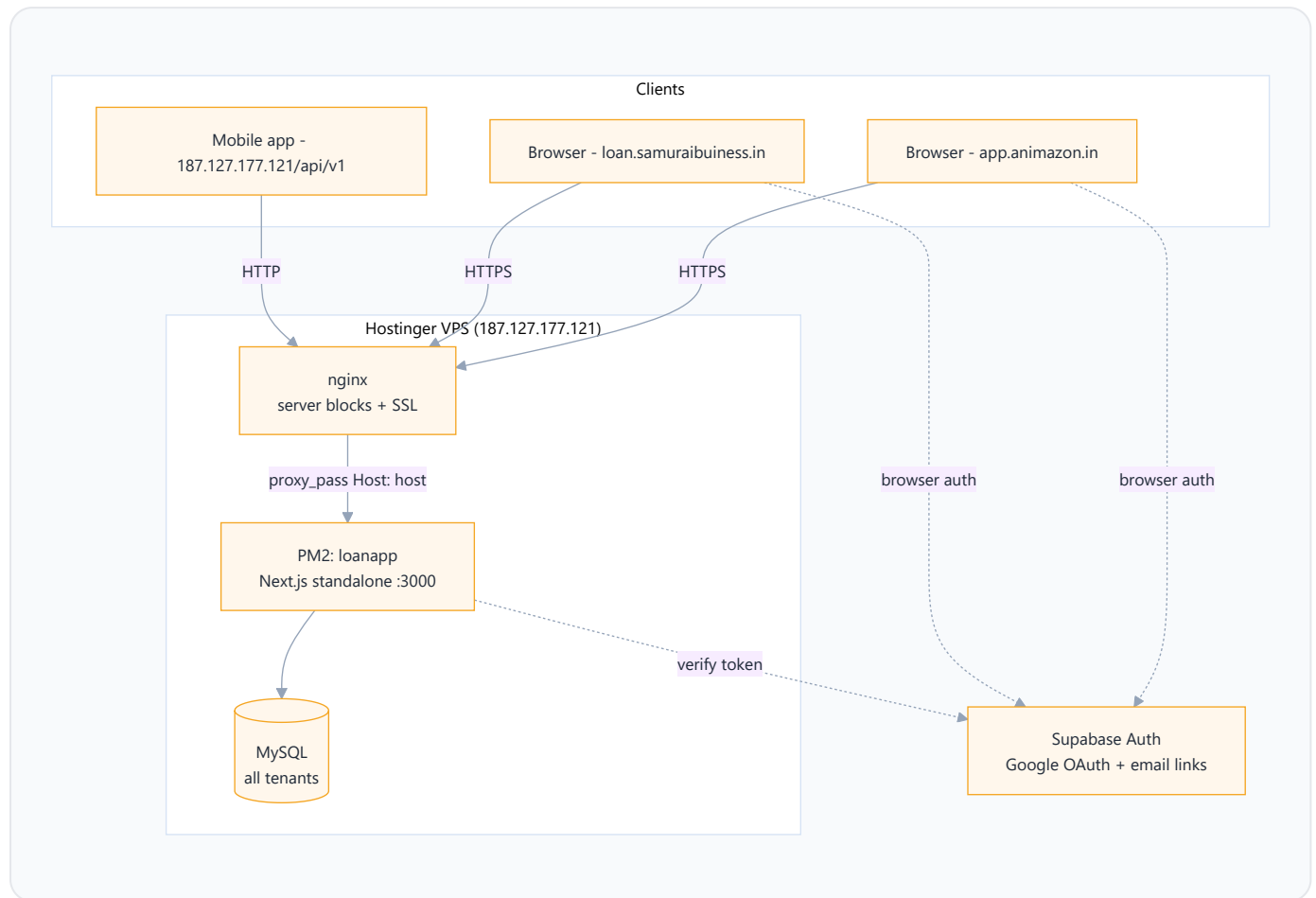
One codebase & one database — SaaS + Standalone Client

	Host	Model	Registration
Our SaaS	<code>app.animazon.in</code>	Multi-tenant, paid subscription	Full 5-step, anyone
Client standalone	<code>loan.samuraibusiness.in</code>	Single tenant, lifetime (no billing)	Details-only, first signup claims & locks

Architecture Reference

Mobile API for both served over the VPS IP `187.127.177.121` (JWT carries the tenant).

1 High-level architecture



Key idea: nginx forwards the original `Host` header. The app resolves *which tenant* from that host. Same process, same DB — behaviour forks on host + license.

2 Host → Tenant resolution (the core fork)

Every request resolves a tenant from the `Host` header. Custom domain is checked **before** the subdomain logic, so a reserved first label (e.g. `loan.*`) can't shadow it.

- Code: `getTenantIdFromHost()` and `getCustomDomainTenantId()` in `lib/tenant.ts` ; login path mirrors this in `resolveLoginTenantId()` (`lib/auth.ts`).
- `NEXT_PUBLIC_ROOT_DOMAIN` is **empty** in prod → cookies stay **host-only**, so a session on `loan.samuraibuiness.in` is never sent to `app.animazon.in` .

3 SaaS domain — `app.animazon.in`

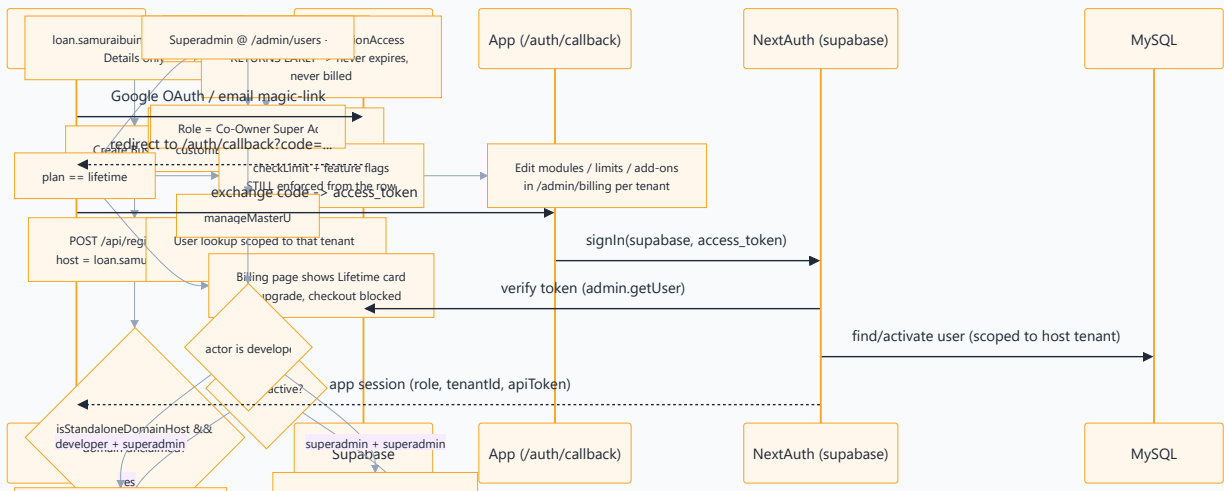
3.1 Registration (full, multi-tenant)

3.2 Login (subscription enforced)

- Subscription gates live in `lib/subscription.ts` (`assertTenantSubscriptionAccess` , `checkLimit`) and are called from `getCurrentTenantId()` (`lib/tenant.ts`).

3.3 Developer "Open account" (no-login tenant access)

Replaces the old "Monitor Mode". A developer enters any tenant without logging in; a sticky banner shows which account.



- Banner: `components/MonitorBanner.tsx` (shows `tenant.name`).
- Exit redirect uses `APP_URL` (not the internal `localhost:3000`).

4 Client standalone — `loan.samuraibusiness.in`

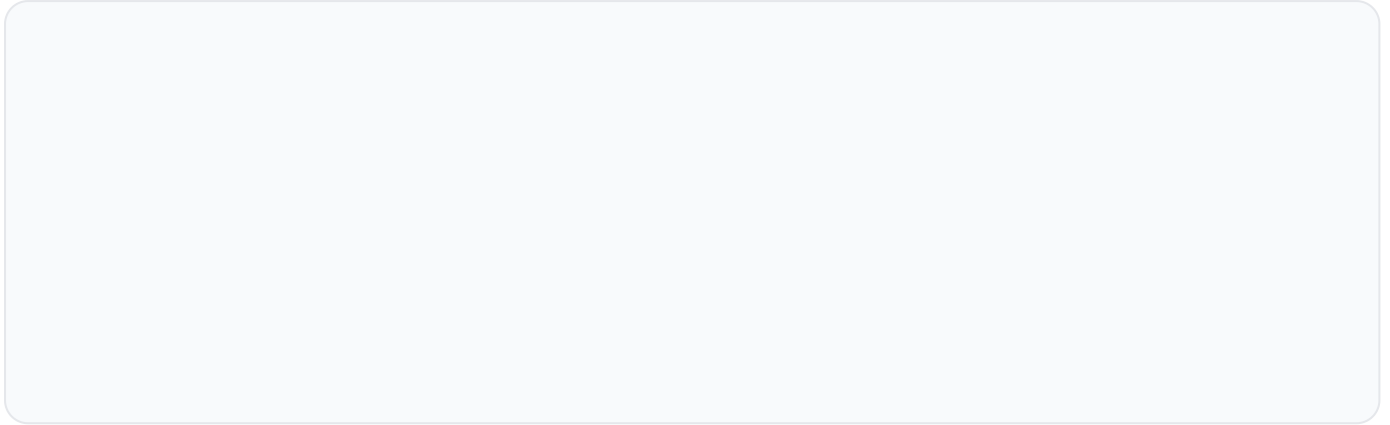
4.1 Registration policy per host

4.2 Self-claim signup (Details-only → lifetime owner → lock)

After the claim, `/api/host/registration` returns `allowed=false` for that host — no second business / superadmin can ever self-register. Extra owners are added **in-app only** (see §6).

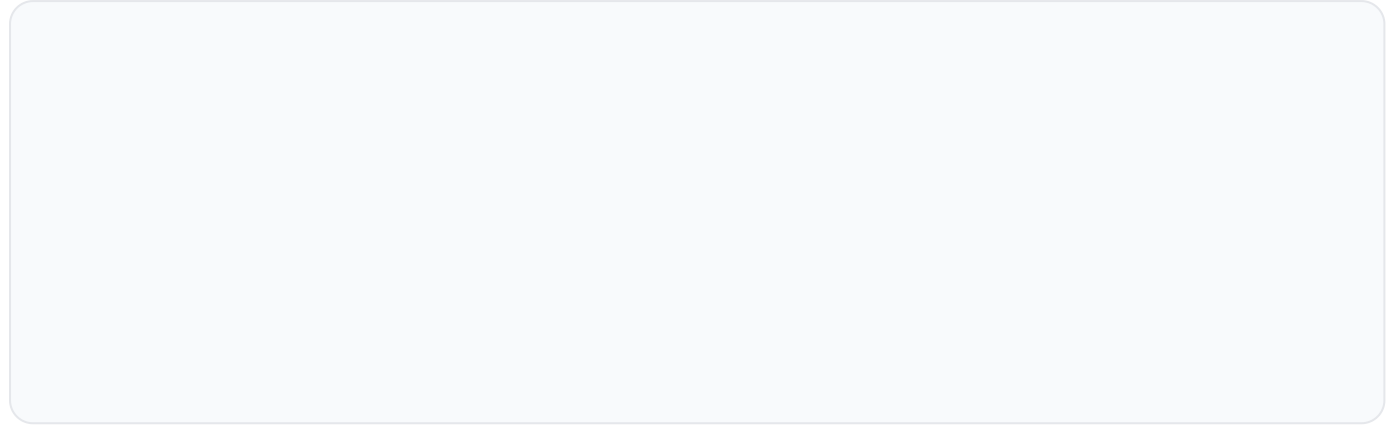
4.3 Login (scoped to the one tenant)

5 Lifetime license model (time-only)



- "Lifetime" = unlimited **time** only. Features, modules and limits remain controlled per-tenant in the admin billing panel (`lib/subscription.ts` , `lib/plans.ts`).

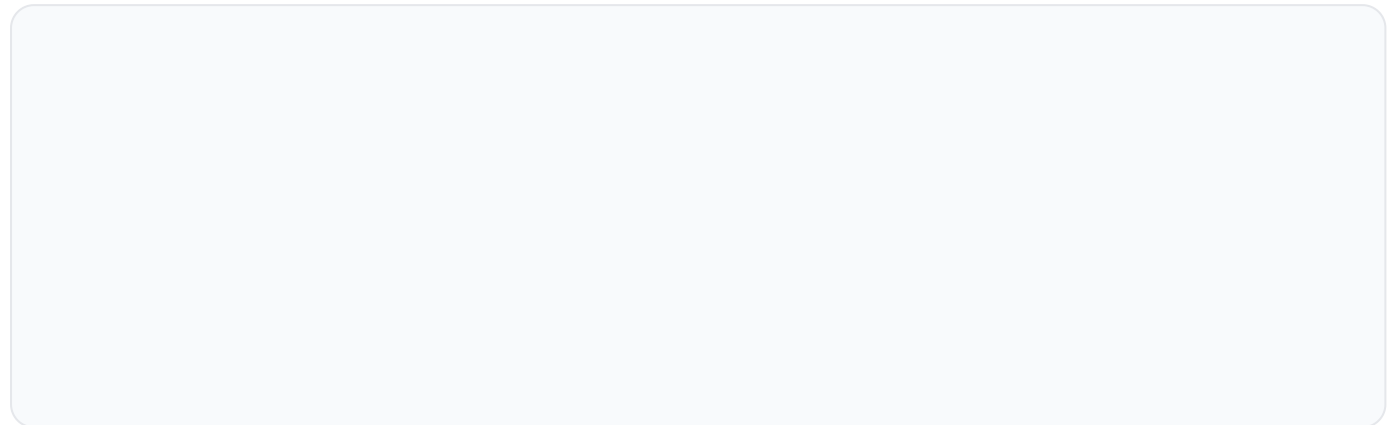
6 Multiple owners (co-owner), in-app only



Created **inside the app** only — never via public registration (blocked on client domains). Logic in `manageMasterUser` (`app/admin/actions.ts`).

7 Supabase auth bridge (both domains)

Supabase is an **auth broker** only (Google OAuth + email magic-link). MySQL keeps users/passwords; NextAuth issues the session.



- Browser ↔ Supabase calls require the Supabase origin in the app's CSP `connect-src` (`next.config.ts`) and the domain in Supabase's redirect allowlist.

8 Infra & config reference

Concern	SaaS (app.animazon.in)	Client (loan.samuraibuiness.in)
nginx	<code>server_name app.animazon.in</code> (default_server)	<code>server_name loan.samuraibuiness.in</code> (samurai.conf)
SSL	certbot	certbot (separate cert)
DNS	A → 187.127.177.121	A → 187.127.177.121
Tenant resolution	subdomain/slug or session	<code>tenant.customDomain</code> exact match
Registration	full, all plans	Details-only, claims lifetime, then locked
Cookie domain	host-only (ROOT_DOMAIN empty)	host-only
Supabase allowlist	<code>https://app.animazon.in/**</code>	<code>https://loan.samuraibuiness.in/**</code>
CORS (CORS_EXTRA_ORIGINS)	n/a (same-origin)	<code>https://loan.samuraibuiness.in</code>

Key files

- Tenant/host: `lib/tenant.ts` (getTenantIdFromHost, getCustomDomainTenantId, isStandaloneDomainHost)
- Auth/session: `lib/auth.ts` (resolveLoginTenantId, supabase provider, apiToken refresh, monitor session)
- Subscription/lifetime: `lib/subscription.ts` , `lib/plans.ts`
- Registration: `app/register/page.tsx` , `app/api/register/email|google/route.ts` , `app/api/host/registration/route.ts`
- Supabase: `lib/supabase/{server,browser}.ts` , `app/auth/callback/page.tsx`
- Developer access: `app/admin/users/UsersClient.tsx` , `app/api/developer/monitor/*` , `components/MonitorBanner.tsx`

Onboarding a NEW standalone client

1. Client buys domain → add DNS **A record** → 187.127.177.121 .
2. Add nginx `server` block for the host → `certbot --nginx -d <host>` .
3. Add `<host>` to Supabase redirect allowlist + `CORS_EXTRA_ORIGINS` .
4. Client visits `https://<host>/register` → Details-only → first signup **auto-claims** lifetime + all modules + locks.
5. Tune modules/limits/add-ons in `/admin/billing` if needed.